Operation False Invoice — Mission Checklist

Mission

Brightline Design received a suspicious invoice email. Investigate the evidence and determine what happened.

Work only with the files in this lab. Record your findings in this checklist as you go.

Start

- [x] Docker container started successfully.
- [x] I opened `/lab/evidence`.
- [x] I listed the evidence files with `ls`.

Mission 1: Inspect the email

- [x] I read `suspicious_email.eml`.
- [x] I read `email_headers.txt`.
- [x] I found the suspicious `Reply-To` address.
- [x] I noticed the failed email authentication checks.
- [ ] Flag 1 recorded: _____

Findings:

- `From: billing@brightline-designs.example` but `Reply-To: accounts-review@brightline-payments.example`. The visible sender and reply address use different domains, so replies would go to an address the sender controls (and neither domain is the recipient's own `brightline.example`).
- `Authentication-Results: spf=fail; dkim=none; dmarc=fail`. SPF fail means the sending server was not authorized for the domain. DKIM none means the message was unsigned. DMARC fail means the visible From address was not backed by an aligned SPF/DKIM pass. Together these are strong spoofing/phishing indicators.
- Urgency language ("Urgent", "before 10:00 AM") is a social-engineering pressure tactic.

Mission 2: Inspect the attachment

- [x] I read `attachment_metadata.txt`.
- [x] I identified the double file extension.
- [x] I compared the hashes in `file_hashes.txt`.
- [x] I determined whether the file matched the known-good viewer.

- [ ] Flag 2 recorded: _____

Findings:

- Displayed name `Invoice_September.pdf` / displayed type "PDF document", but actual name is `Invoice_September.pdf.exe` and actual type is a **Windows executable**. The double extension hides the real `.exe` ending.
- SHA256 of the attachment (`3e6f9cc7...`) does **not** match the known-good invoice viewer (`9a1b4c8d...`), so it is not the legitimate viewer.
- Note: the attachment hash line is 63 hex characters (a SHA256 is 64), so it appears malformed. The "no match" conclusion holds, but the hash should be re-verified.

Mission 3: Identify the employee

- [x] I reviewed `employee_activity.log` .
- [x] I reviewed `browser_history.txt` .
- [x] I used `employee_directory.txt` to identify the employee and department.
- [ ] Flag 3 recorded: _____

Findings:

- `employee_activity.log` : `2026-09-28 09:42:04 employee=j.miller action=opened file=Invoice_September.pdf.exe` .
- `browser_history.txt` : `09:42:21 file:///Users/jmiller/Downloads/Invoice_September.pdf.exe` .
- `employee_directory.txt` : j.miller = **Jordan Miller**, Employee ID 1042, **Accounts Payable**, Invoice Specialist.

Mission 4: Investigate the activity

- [x] I reviewed `process_list.txt` .
- [x] I reviewed `auth.log` .
- [x] I identified the suspicious process and credential prompt.
- [x] I identified the account involved.

Findings:

- Suspicious process: `invoice_viewer.exe` (PID 311, user j.miller), started 09:42:07 (3 seconds after the attachment opened), running from `C:\Users\j.miller\AppData\Local\InvoiceSync\` , a user-writable folder, not a normal install location.
- Credential prompt: `auth.log` `09:44:11 event=credential_prompt source=invoice_viewer.exe` , then `09:44:19 event=credential_submitted source=invoice_viewer.exe` . A credential was entered into an unverified executable.

- Account involved: **j.miller** (Jordan Miller). Credentials should be treated as compromised.

Mission 5: Find persistence

- [x] I reviewed `startup_tasks.txt`.
- [x] I found the task that runs at logon.
- [x] I explained why this is a security concern.
- [ ] Flag 4 recorded: _____

Findings:

- Task `InvoiceSync`, user j.miller, **Trigger: At log on**, program `C:\Users\j.miller\AppData\Local\InvoiceSync\invoice_viewer.exe`. Created at 09:43:19 per `employee_activity.log`.
- Why it matters: it relaunches the suspicious program every time Jordan logs in, so the attacker keeps access even after a reboot or after the original attachment is deleted.
- `BackupSync` (SYSTEM) is the legitimate-looking task and is separate from `InvoiceSync`.

Mission 6: Correlate the evidence

- [x] I reviewed `incident_notes.txt`.
- [x] I connected evidence from at least three files.
- [ ] Flag 5 recorded: _____

Findings (note, then supporting files):

- 09:30 email received: **not supported**. The email `Date` and Message-ID both show 09:38:12.
- 09:38 delivered to Jordan Miller: supported by `suspicious_email.eml`, `email_headers.txt`, `employee_directory.txt`.
- 09:42 attachment opened: supported by `employee_activity.log`, `auth.log` (filewatcher), `browser_history.txt`.
- 09:44 login prompt from invoice viewer: supported by `auth.log`, `employee_activity.log`, `browser_history.txt`.
- 09:45 scheduled task under backup service account: only `auth.log` (`user=backupsvc ... source=scheduled_task`) shows it. Nothing links it to the attack, so it is not confirmed as malicious.
- Account involved throughout 09:42 to 09:44: **j.miller**.

Final debrief

- [x] I wrote a short timeline of what happened.
- [x] I listed three indicators of compromise.
- [x] I listed three actions the company should take.

- [ ] I explained my conclusion to the instructor or event facilitator.
- [ ] Flag 6 recorded: _____

Timeline (2026-09-28):

- 09:38:12 Phishing email with `Invoice_September.pdf.exe` sent to j.miller (SPF fail, DKIM none, DMARC fail).
- 09:41:58 j.miller logs in at the local console.
- 09:42:04 j.miller opens the attachment.
- 09:42:07 `invoice_viewer.exe` starts from AppData.
- 09:43:19 `InvoiceSync` scheduled task created (runs at logon).
- 09:44:02 to 09:44:15 login-page requests to the portal.
- 09:44:11 to 09:44:19 credential prompt shown and credentials submitted via `invoice_viewer.exe`.
- 09:45:01 backupsvc scheduled-task logon (context only, not tied to the attack).

Three indicators of compromise:

1. Email authentication failure (SPF fail, DKIM none, DMARC fail) plus a Reply-To on a different domain.
2. `Invoice_September.pdf.exe`: a double-extension executable disguised as a PDF.
3. `invoice_viewer.exe` running from `AppData\Local\InvoiceSync\`, launched by the new `InvoiceSync` logon task, and prompting for credentials.

Three recommended actions:

1. Isolate workstation-07 and reset j.miller's password (and revoke active sessions/tokens).
2. Remove the `InvoiceSync` task and `invoice_viewer.exe`, then scan the machine and verify the file hashes.
3. Block the sender and Reply-To domains, enforce DMARC `reject` and attachment filtering for executables, and run phishing awareness training for Accounts Payable.

Finished

- [x] All checklist items are complete.
- [ ] All six flags are recorded.
- [x] My team is ready to explain the incident in one minute.